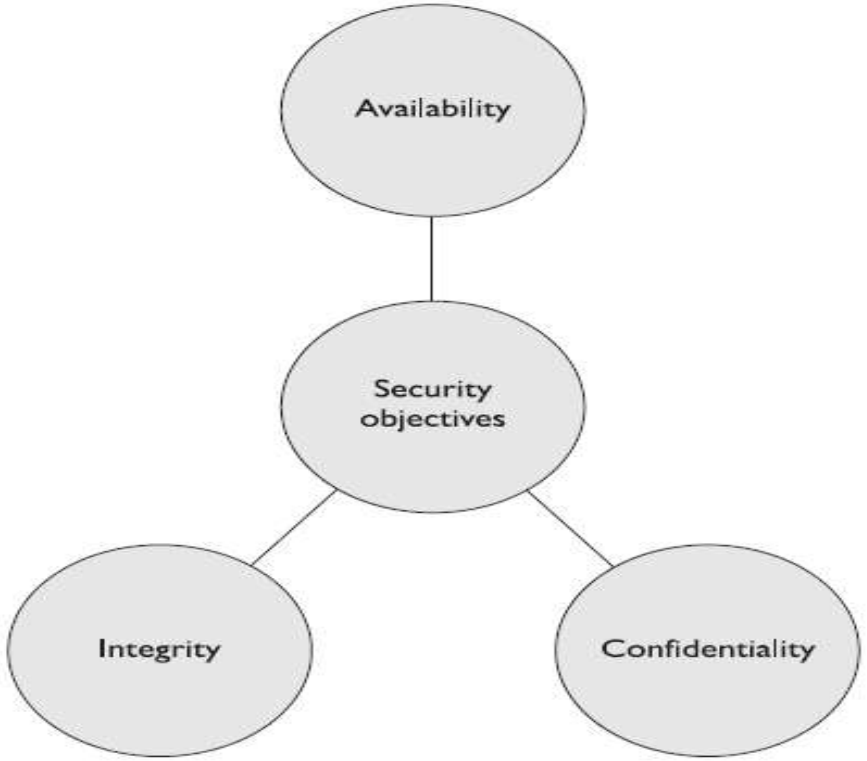
# 1.1 密码学简介

- 密码学是信息安全的重要组成部分
- 信息安全三要素
  - 机密性
  - 完整性
  - 可用性



# 机密性

- 确保信息不被非法获取
- 常见威胁
  - 窃听
  - 盗窃文件
  - 社会工程学

    ……

# 完整性

- 确保系统或数据被恶意篡改后，我们能够发现
- 导致破坏完整性的原因
  - 合法用户的失误
  - 非法用户的篡改

# 可用性

- 确保系统以足够的能力、预期的方式、可接受的性能提供服务
- 导致破坏可用性的原因
  - 设备故障
  - 软件错误
  - 环境因素
  - 人为攻击
  - 典型代表：DoS攻击(拒绝服务攻击)

# 密码学的基本术语

- 明文：需要保护的信息
- 加密：隐藏信息的过程
- 密文：加密后的明文
- 解密：从密文恢复出明文的过程
- 密码分析：对密码进行破译的过程

# 密码学的基本原则——柯克霍夫斯原则

- 柯克霍夫斯原则

  即使密码算法的任何细节已为人所知，只要密钥没有泄漏，它也应是安全的。

- 另一种表述

  密码算法的安全性是基于密钥的安全性，而不是基于保密算法细节。



Auguste Kerckhoffs
1835 –1903
荷兰语言学家、密码学家

# 柯克霍夫斯原则的意义何在？

- 意义在于，密码算法很难做到保密
  ① 知道算法的人可能会叛变——历史上这种事屡见不鲜
  ② 设计者有个人喜好
  ③ 频繁更换密钥是可能的，但无法频繁更换密码算法 (因为设计安全的密码算法相当困难)

# 4.1.1 Hash函数概述

- 定义
  - 又称哈希函数、杂凑函数、散列函数
  - 是一个将任意长度的消息映射成固定长度输出的函数

$$H:\{0,1\}^{*}\rightarrow\{0,1\}^{n}$$

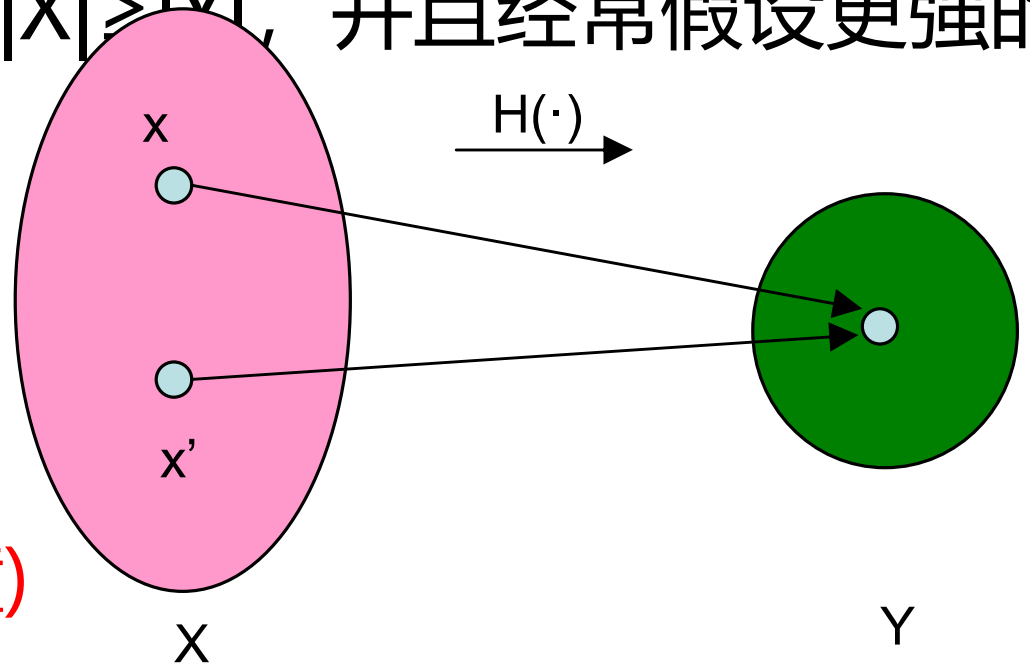
    - 其输入称为“消息”
    - 其输出称为“散列值” (Hash值、消息摘要)
    - n是散列值的长度

- 通过定义可以知道，散列值是消息所有比特的函数
- Hash函数应该实现这样的功能：
  - 改变消息的一个比特或几个比特都会使散列值发生改变

- 通常，Hash函数是一个具有压缩功能的函数
  - 设X是消息的集合，Y是散列值的集合
  - 我们总是假设|X|≥|Y|，并且经常假设更强的条件|X|≥2|Y|。

根据鸽巢原理：两个甚至多个消息会映射为同一个散列值

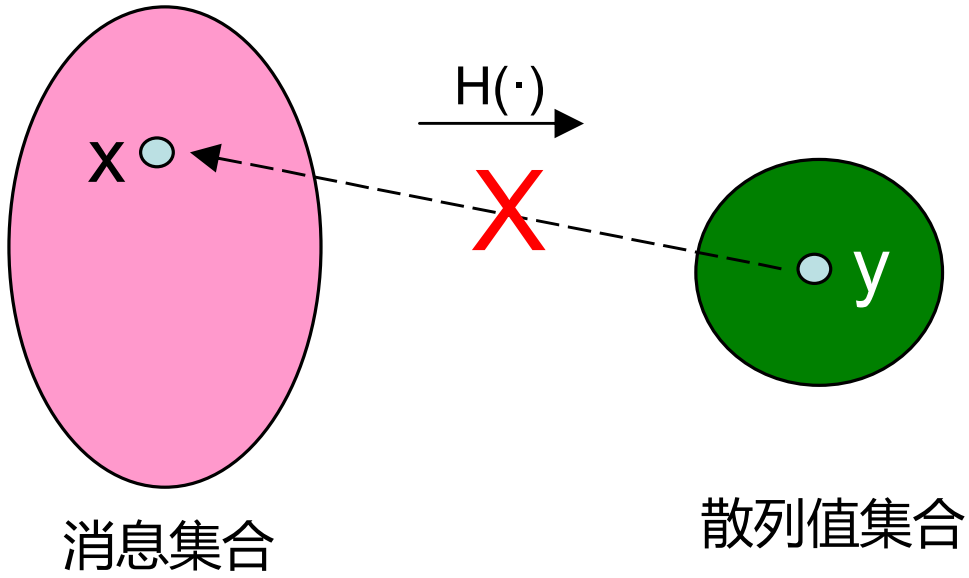
(称x和x'是一对碰撞)



# 4.1.2 Hash函数的安全性

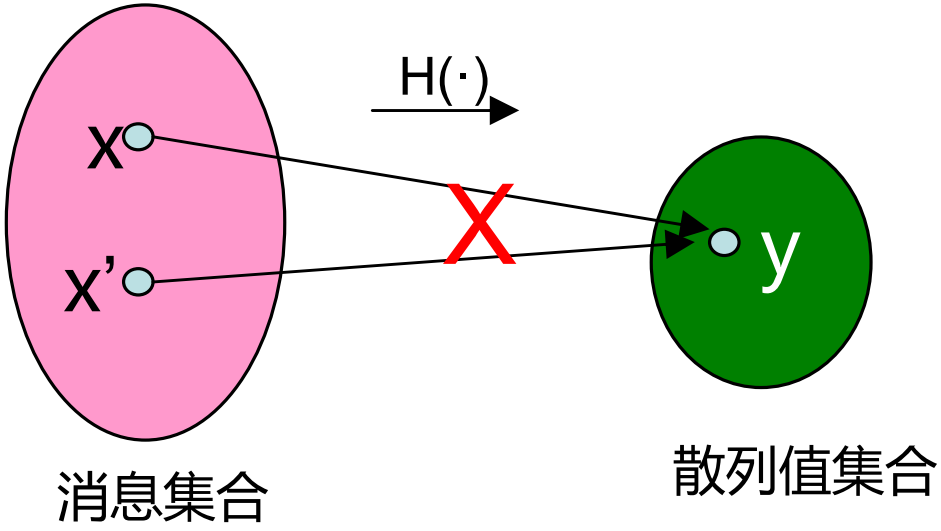
- Hash函数的分类
  ① 单向Hash函数
  ② 弱抗碰撞Hash函数
  ③ 强抗碰撞Hash函数

- 原象稳固
  - 给定散列值y，要找到其原象x，使得H(x)=y是困难的




满足该性质的Hash函数称为“单向Hash函数”

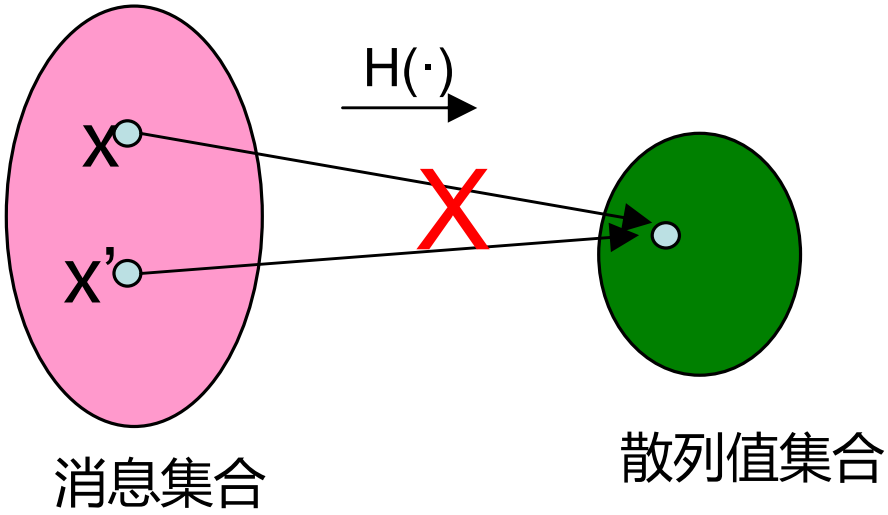
- 第二原象稳固
  - 已知H(x)=y，找到另一个x’，使得H(x’)=y是困难的




满足该性质的Hash函数称为“弱抗碰撞Hash函数”

- 碰撞稳固

  找到任意一对x、x’(两个不同的消息)，使得H(x)=H(x’)是困难的。




满足该性质的Hash函数称为“强抗碰撞Hash函数”

# 几个著名的Hash函数

1. MD5
   - 时间：1992年
   - 发明者：R.Rivest
   - 相关文档：RFC 1321
   - 输入：将消息分成512比特一组处理
   - 散列值长度：128比特
   - 应用领域：商业
   - 特性
     - 直接构造法: 不依赖任何密码模块和假设条件
     - 算法简洁，计算速度快
     - 特别适合32位计算机软件实现

2. SHA系列 (SHA-0、SHA-1、SHA-2)
   - 时间：1993年，1995年的修改版称为SHA-1
   - 开发者：NIST、NSA
   - 相关文档：FIPS 180，联邦信息处理标准
   - 应用领域：美国政府
   - 运行速度比MD5慢
   - SHA–1输入：将消息分成512比特一组处理(与MD5相同)，整个消息长度小于$2^{64}$
   - SHA–1散列值长度：160比特

- MD5是金融业、数据库系统等首选的Hash函数
- 很多学者和爱好者投入到对它破译的工作中(寻找碰撞)，甚至出现很多相关的网站
- 在诸多攻击中，我国学者王小云的方法最具威胁
- 在CRYPTO’04学术会议上，王小云做了破译MD5的学术报告，令国际顶尖密码专家为之震惊
- 这次会议的总结报告是这样写的
  - 我们该怎么办？MD5被重创了，它即将从应用中淘汰。SHA-1仍然活着，但也见到了它的末日。现在就得开始更换SHA-1了。

- 既MD5被破译之后，密码学界仍认为SHA-1是安全的
- 2005年，NIST宣布
  - SHA-1还没有被攻破，也没有理由怀疑它的安全性
- 但仅在一周之后，王小云又令密码学界大跌眼镜
  - SHA-1也被她破译了

- 因为SHA-1应用比MD5广泛，美国政府早在1994年就开始使用SHA-1
- 因此SHA-1崩溃的影响甚至超过半年前MD5的坍塌
- 美国政府宣布5年内不再使用SHA-1，并对SHA-1进行改进
- 目前，美国政府已逐渐减少使用SHA-1，而改用SHA-2系列

- SHA-2系列
  - ① SHA-224
    - 散列值224比特
    - 安全性增加到112位
  - ② SHA-256
    - 散列值256比特
    - 安全性增加到128位
  - ③ SHA-384
    - 散列值384比特
    - 安全性增加到192位
  - ④ SHA-512
    - 散列值512比特
    - 安全性增加到256位

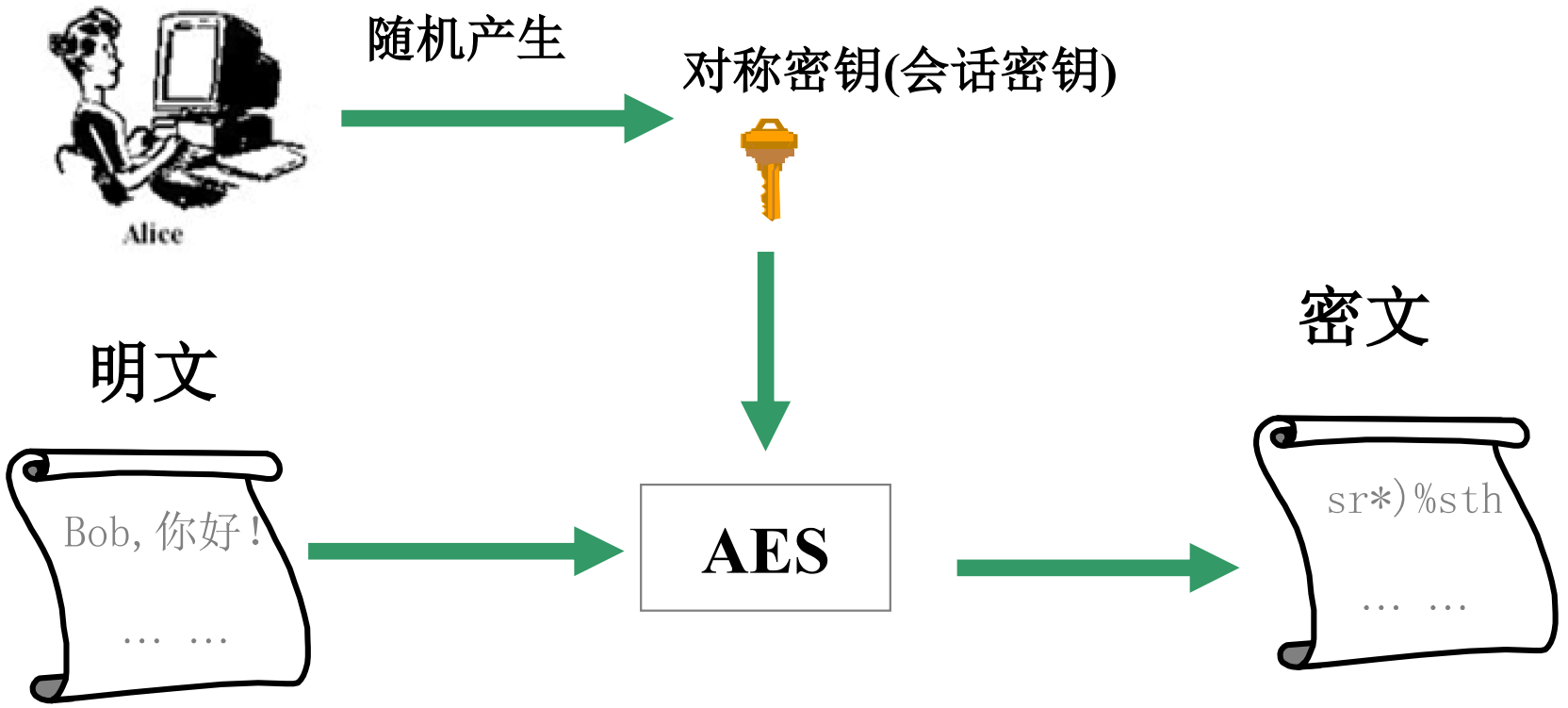
- 尽管王小云的成果真正应用到实际中还有一段路程要走，但至少证明了MD5和SHA-1存在很大的安全问题。
- 在密码学的学术理论中，任何攻击方法的计算复杂度若少于穷举攻击，就被视为成功的攻击，但这并不表示该方法已经可以进入实际应用的阶段。
- 不过，就应用层面而言，一种新破译方法的出现，暗示着将来可能会出现效率更高、更实用的改良版攻击法。
- 虽然这些实用的破译改良版根本还没诞生，但确有必要发展更强的算法来取代旧的算法。
- 因此，美国政府以及密码学界对王小云的成果感到震惊，甚至兴师动众并非小题大做。

| 对称密码 | 公钥密码 |
| --- | --- |
| **●一般要求：**<br>1、加密解密用相同的密钥<br>2、收发双方必须共享密钥<br><br>**●安全性要求：**<br>1、密钥必须保密<br>2、没有密钥，解密不可行<br>3、知道算法和若干密文不足以确定密钥 | **●一般要求：**<br>1、加密解密使用不同的密钥<br>2、发送方拥有加密或解密密钥，而接收方拥有另一个密钥<br><br>**●安全性要求：**<br>1、私钥必须保密，公钥可以公开<br>2、没有私钥，解密不可行<br>3、知道算法和公钥，以及若干密文不能确定私钥 |

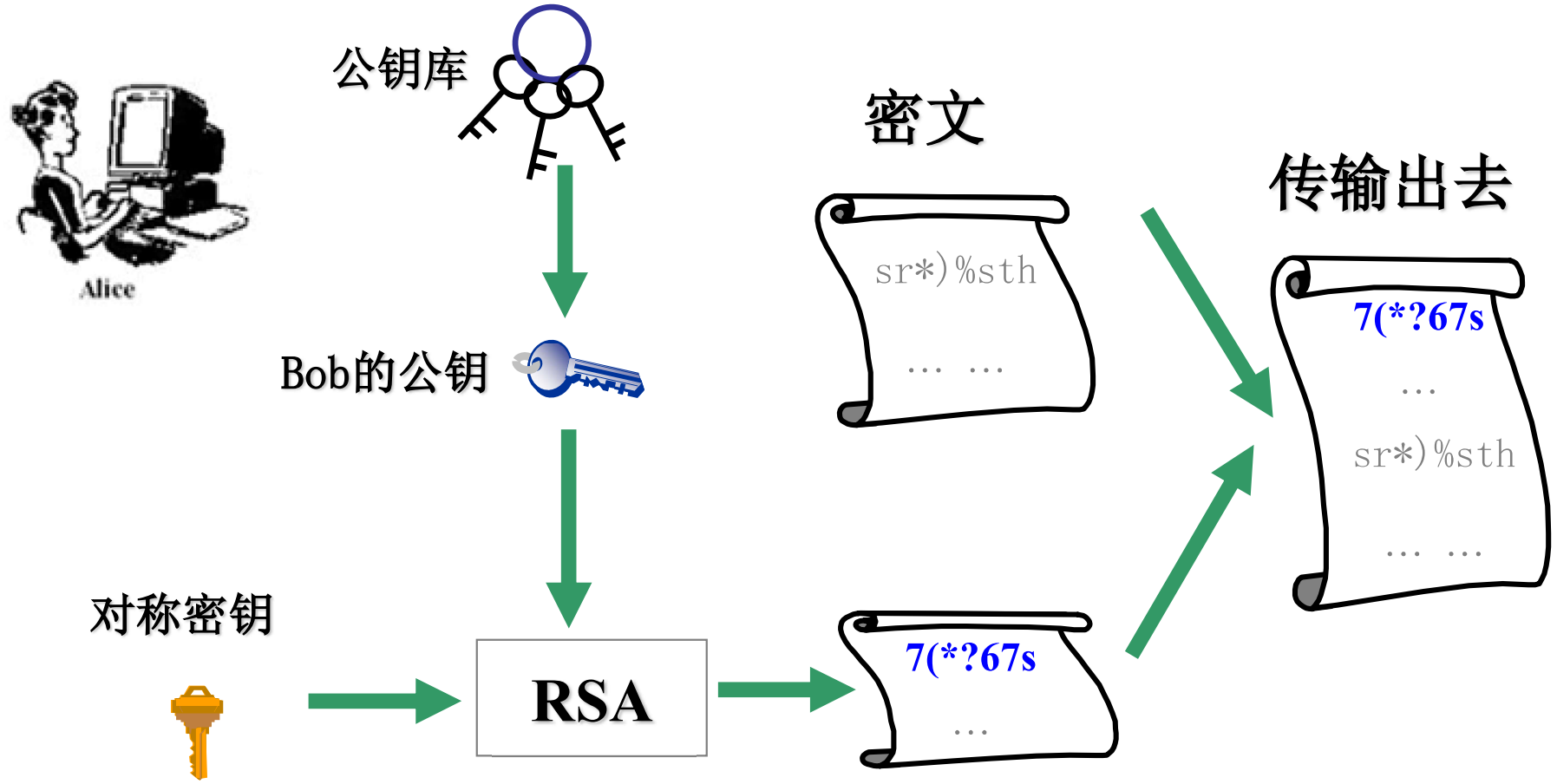
# 6.6 数字信封

- 对称密码、公钥密码各有长短
  - 对称密码体制：高效，适用于加密大量数据，但密钥分发困难
  - 公钥密码体制：效率低，不适于加密大量数据，但灵活
- 数字信封(Digital Envelope)
  - 目的：取长补短，利用对称密钥加密数据，用接收者公钥保护该对称密钥

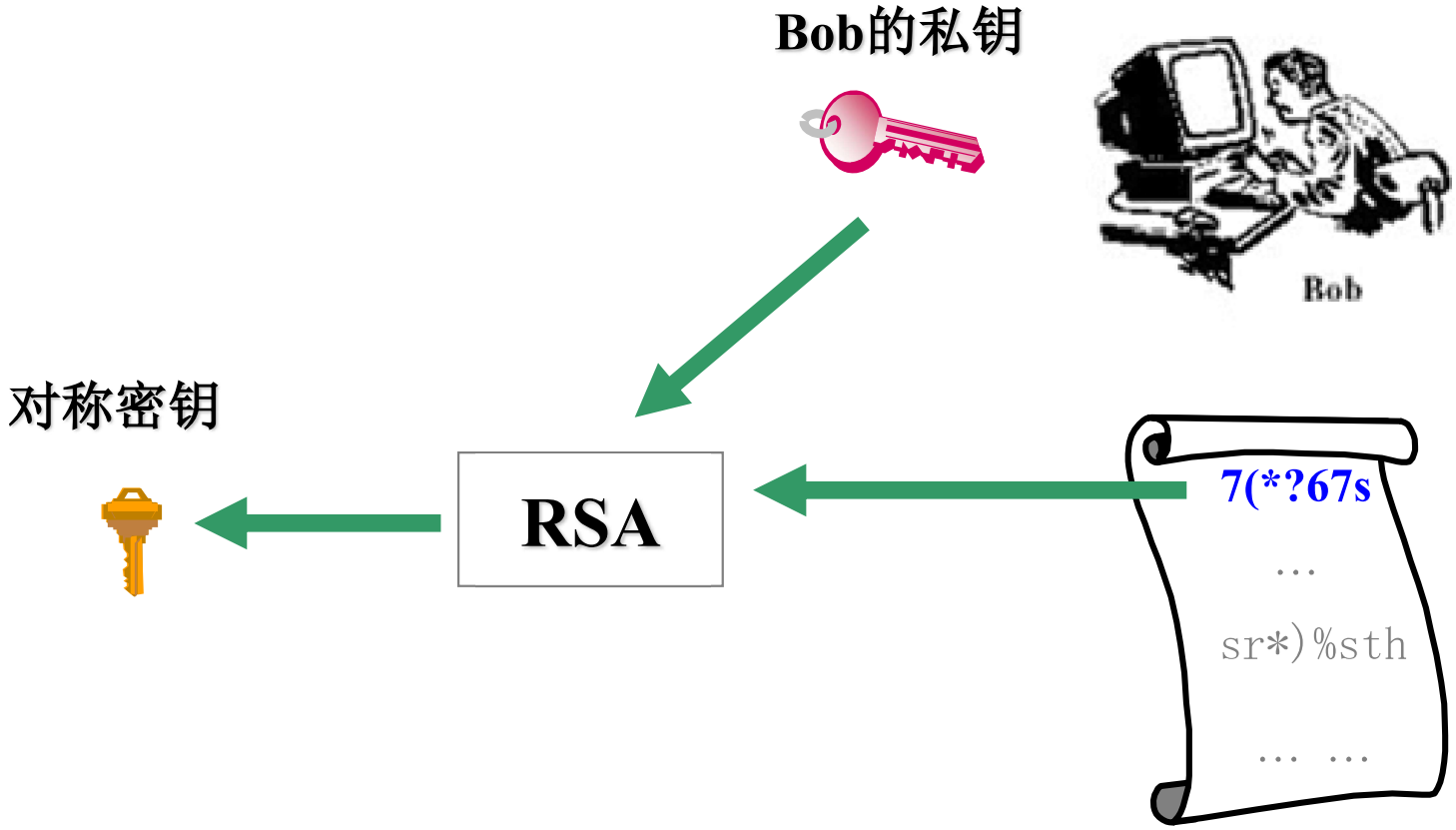
- Alice的加密过程：
  - 用对称密码体制加密数据



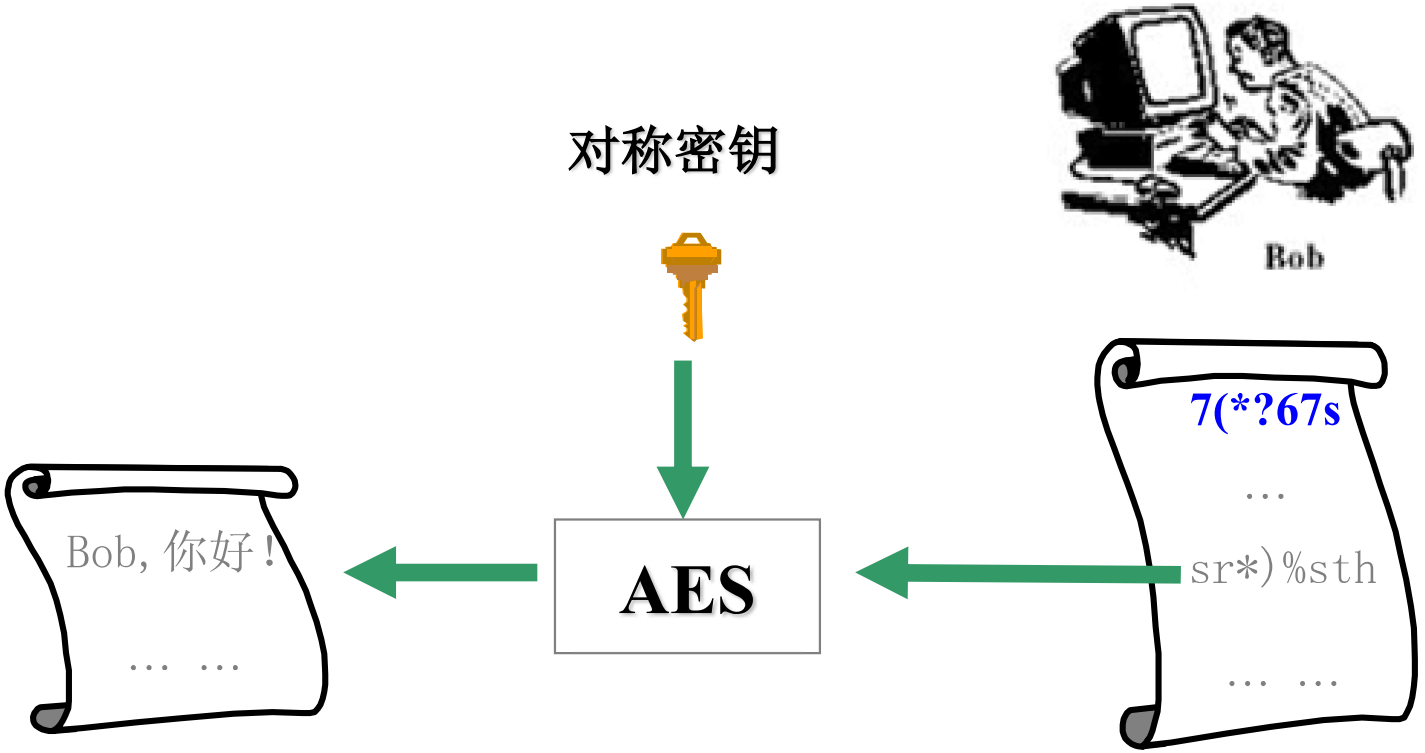
– 用公钥密码体制保护对称密钥



- Bob在接收端的解密过程：
  - 用私钥恢复对称密钥



– 用对称密钥恢复明文



# 数字信封总结

- 发送方
  ① 随机生成对称密钥, 用该密钥加密明文
  ② 用接收方的公钥加密该对称密钥
  ③ 将①、②的结果发送给接收方
- 接收方
  ① 用自己的私钥恢复对称密钥
  ② 用该对称密钥解密密文
- 考虑数据完整性的话，还应加入完整性技术